

JuiceBox Retail Pvt. Ltd.

4th Floor, Orion Tech Park, Whitefield, Bengaluru, Karnataka 560066

Document	Request for Security Assessment Services (RFP and Statement of Work)
Engagement reference	JB/SEC/2026/021
Date of issue	02 September 2026
Issued to	EPCET Security Research Laboratory — Semi-Autonomous Red Teaming Team
Primary client contact	Ananya Rao — Chief Information Security Officer ciso.office@juiceboxretail.example +91 80 4XXX 2100 (ext. 401)
Test window	04 September 2026 to 10 September 2026 (both days inclusive)
Classification	Confidential — Client and Assessment Team only

1. Cover letter from the client

Dear EPCET Security Research Laboratory — Semi-Autonomous Red Teaming Team,

JuiceBox Retail Pvt. Ltd. ("JuiceBox", "the Company") is preparing to launch a new customer-facing e-commerce storefront. Under engagement JB/SEC/2026/014 your team performed the initial pre-launch assessment of the release-candidate deployment. As launch approaches, the Company now requires a substantially deeper second-pass assessment of the same laboratory environment: full service and version enumeration, a complete HTTP security-header audit, technology fingerprinting, cookie and transport review, and rate-limited template-driven vulnerability checks, all correlated into one prioritized report.

We request your team to perform a non-destructive external and web-application security assessment of the assets identified in Section 3 of this document, strictly within the authorized scope stated therein, during the test window stated above. We understand that your assessment methodology is semi-autonomous: automated reconnaissance and scanning steps are proposed by your framework and must be individually reviewed and approved by your human operator before execution. This is acceptable to the Company, and we specifically require that this human approval step remain in force for every command issued against our assets. Given the depth requested, the Company also asks that the final report quantify the coverage achieved relative to the manual effort an unaided tester would have required, as described in Section 6.

All systems listed in Section 3 are owned or controlled by the Company. No third-party, shared-hosting, or cloud-provider infrastructure is included in scope. Please sign and return the authorization in Section 8 to confirm your acceptance of these terms.

Yours sincerely,

Ananya Rao
Chief Information Security Officer
JuiceBox Retail Pvt. Ltd.

2. Background and business context

JuiceBox Retail operates a loyalty and retail platform serving approximately 240,000 registered customers. The pre-release storefront (internally named "Juice Shop") is a new Node.js-based e-commerce application scheduled to go live at the end of Q3 2026. The initial assessment under engagement JB/SEC/2026/014 confirmed basic exposure but was deliberately shallow. The Company is now contractually obliged to its payment partners to evidence a deeper pre-launch vulnerability assessment covering the full external attack surface. The assessment requested here is that evidence.

The Company additionally maintains an internal web-application security-training system (internally named "DVWA Lab") used by the IT team. A baseline assessment of this training system is requested under the same engagement for calibration purposes, as described in Section 3.2.

3. Authorized scope of the assessment

3.1 Primary asset — pre-release storefront (in scope, deep assessment)

The following asset is the only production-relevant system authorized for this engagement. All testing activity must be directed exclusively at it.

Attribute	Value
System name	Juice Shop pre-release storefront
Authorized target address	juice-shop:3000 (assessment-lab network)
Authorized scope identifiers	juice-shop, juice-shop:3000
Technology	Node.js / Express web application, HTTP on TCP port 3000
Asset criticality (client-declared, 0-100)	90 — customer-facing e-commerce platform, weeks from launch
Assessment type	Deep external and web-application assessment (full framework toolset, subject to Section 5.3)
Environment	Isolated laboratory deployment (Docker), mirrors release-candidate build

3.2 Secondary asset — internal training system (in scope, baseline only)

Attribute	Value
System name	DVWA internal security-training lab
Authorized target address	dvwa:80 (assessment-lab network)
Authorized scope identifiers	dvwa, dvwa:80
Technology	Apache / PHP / MySQL training application, HTTP on TCP port 80
Asset criticality (client-declared, 0-100)	45 — internal training system, no production data
Assessment type	Service discovery and HTTP header baseline only (see Section 5.4)

The client-declared criticality values above must be supplied to the assessment framework when each target is registered, because they feed the risk-priority scoring of the findings in the final report.

3.3 Assets explicitly OUT OF SCOPE

The following are **strictly out of scope**. Any traffic, scanning, probing or enumeration directed at these systems is a breach of this agreement and must not occur:

- Any host other than the two assets named in Sections 3.1 and 3.2, including any address obtained by DNS enumeration or referenced in application responses.
- JuiceBox corporate network, employee endpoints, VPN concentrators and mail servers.
- Third-party payment gateways, CDN providers, analytics or any externally hosted service.
- Any production system of the Company, including the currently live legacy storefront.
- Social engineering, phishing, or any testing involving JuiceBox personnel.
- Physical security testing of any JuiceBox premises.

4. Assessment objectives

The Company requests that the assessment pursue the following objectives, in priority order:

- **4.1 Service and version discovery:** identify every network service and software version exposed by the authorized targets, using lightweight active discovery (nmap service version detection restricted to the listed ports).
- **4.2 HTTP security-header audit:** enumerate the complete set of HTTP response headers on each web target and report every missing or weakly configured browser security header (Content-Security-Policy, Strict-Transport-Security where applicable, X-Frame-Options, X-Content-Type-Options and Referrer-Policy) together with a per-header explanation and remediation.
- **4.3 Technology fingerprinting:** identify disclosed technology fingerprints (server banner, framework markers, X-Powered-By style headers) that would assist an attacker in selecting exploits, using automated fingerprinting tools.
- **4.4 Cookie and transport review:** review the security flags of any session cookie set by the storefront, and characterise the transport-security configuration of each web target where a TLS endpoint exists.
- **4.5 Rate-limited known-vulnerability checks:** where safe template-driven checks exist (e.g. nuclei with non-invasive templates), identify publicly documented weaknesses in the web tier without exploiting them, strictly rate-limited as required by Section 5.1.
- **4.6 DNS and name characterization:** resolve and characterise the name resolution of the authorized scope identifiers, to confirm addressing and support exposure analysis.
- **4.7 Findings correlation and prioritization:** consolidate all findings, remove duplicates, and rank them by severity, risk, business criticality and confidence, so that the Company can schedule remediation before launch.

5. Rules of engagement

5.1 General conduct

- Testing is restricted to the test window stated on page 1. No activity outside the window is authorized.
- Every individual command must pass the assessment team's policy review and receive explicit human approval before execution. The Company does not authorize unattended or fully automated execution.
- All activity must remain within the authorized scope identifiers listed in Section 3. Commands whose target resolves outside this scope must be refused by the framework.
- All active scanning must be rate-limited to a maximum of 30 packets or requests per second (e.g. nmap --max-rate 30, nuclei -rl 30), so that no target is saturated.
- The assessment team must keep a complete audit trail of every approved command, its output, exit status, duration, and the fact of human approval. This audit trail forms part of the required deliverables.

5.2 Prohibited techniques (non-exhaustive)

- Denial-of-service, resource exhaustion, or any action intended to degrade availability.
- Destructive testing, data deletion, or modification of application data or configuration.
- Exploitation of identified vulnerabilities beyond proof that the vulnerability exists (no payload execution, no privilege escalation, no data exfiltration beyond a single benign marker).
- Brute-force, credential-stuffing, or password attacks against any authentication mechanism.
- Persistence mechanisms of any kind (web shells, scheduled jobs, modified startup files).
- File upload to, or file writing on, the target systems, including scanner flags that write output files.
- Egress of target data to any third-party or out-of-band collection server.

5.3 Technique restrictions specific to the storefront (Section 3.1)

The laboratory network is shared with other assessment teams during this window. To keep packet volume low, traceroute must not be run against the storefront. All other discovery and inspection tools enumerated by the assessment framework remain authorized for this target, subject to the rate limit in Section 5.1.

5.4 Technique restrictions specific to the DVWA training system (Section 3.2)

Because the training system contains intentionally vulnerable code, only service discovery (nmap) and HTTP header inspection (curl, whatweb) are authorized against it. Template-driven vulnerability checks (e.g. nuclei) and every other tool must not be run against the DVWA lab.

5.5 Incidents and escalation

If any activity causes an unintended service disruption, or if the team discovers evidence of an actual security compromise, all testing must stop immediately and the escalation contact must be notified: **Vikram Shetty — Head of IT Infrastructure, +91 98XXXXXXX (24x7)**. Work may resume only after written confirmation from the Company.

6. Expected deliverables and acceptance criteria

#	Deliverable	Acceptance criterion
1	Assessment report (HTML) covering both authorized targets, produced by the framework's reporting module.	Contains an executive summary, the analysis mode used, and prioritized findings with severity, risk score, priority score, confidence, affected endpoint, scoring breakdown, evidence, remediation and the client-declared asset criticality.
2	Complete execution audit trail.	Every approved command recorded with its raw output, exit code, duration, attempt count and human-approval record.
3	Policy-refusal evidence.	Evidence that out-of-scope and prohibited commands were refused before execution, with the policy reason shown.
4	Remediation summary for the pre-release storefront.	Each finding mapped to a concrete remediation action, ordered by priority score.
5	Automation-benefit statement.	A statement of the number of commands executed, the wall-clock duration of the automated assessment, and the equivalent manual effort an unaided tester would require to reach the same coverage, so the Company can evaluate the efficiency of the semi-autonomous methodology.

The Company requires that the final report clearly state the mode of analysis used (automated AI-provider analysis or the framework's deterministic local analyzer), so that the Company can weigh the findings accordingly.

7. Information handling and confidentiality

- All findings, reports, and target outputs are classified Confidential and are to be shared only between the named contacts in this document and the assessment team.
- Any API keys or credentials configured during the engagement must be stored encrypted and must never be returned in cleartext by any interface of the framework.
- The assessment team must delete all retained client data within 30 days of report acceptance, except anonymized, aggregated metrics required for academic publication.
- Any academic publication resulting from this engagement must present the environment as a laboratory deployment and must not disclose the Company's name or identifiable system details. The present document is a fictional scenario prepared for laboratory demonstration and publication purposes.

8. Client authorization and acceptance

By signing below, the Company confirms that the assets listed in Section 3 are owned or controlled by the Company and authorizes the assessment team to conduct the activities described in this document, within the stated scope, rules and time window. The assessment team accepts the rules of engagement by counter-signing.

	For the Company (client authorization)	For the assessment team (acceptance)
Name	Ananya Rao	_____
Role	Chief Information Security Officer	Team lead, red teaming framework
Signature	_____	_____
Date	02 September 2026	_____

A signed copy of this authorization must be retained by both parties for the duration of the engagement and must be produced on request during the assessment.